Handoff 44: Pyodide pinned and checked (master run WE7, SEC-05)

Date: 2026-11-09 (America/Toronto)
Written by: Claude Code (implementer), in a separate git worktree
For: the human maintainer, and ChatGPT or Claude chat (reviewer) without repository access
Status: **in_review**: one pull request, not merged, not deployed. **No migration, no new dependency.** Changes the worker's Content-Security-Policy, by removing something.

> **How to use this file:** upload it with `docs/plan/browser-checks.md` sections 9 and 13. The pull request diff is the source of truth (`build.md` section 14).

Starter prompt for the chat assistant

```
You are reviewing SEC-05 for Python Academy: the browser worker now checks every Pyodide
file it
starts from against a pinned SHA-256 hash, runs the two scripts from those checked bytes
instead of
importScripts(), and no longer allows scripts from the CDN in its policy. Check that a
changed file
can never run, that nothing new reaches learner code, and that "eval of checked bytes" is
no weaker
than importScripts from a pinned URL.
```

Run plan details

Field	Value
Stage	WE7, first part: SEC-05. SEC-08 (pinned CI actions) is already merged (#41)
Base	`main`, at `1dc4b59`, after #51 merged
Part 2 boxes relied on	**None**
Merge order	Any. Conflicts only in `docs/run-log.md` and the end of `browser-checks.md`, with other PRs from tonight

1. Step 0

`git fetch --all` and `gh pr list --state all`: no PR open. Worktree `../python-academy-sec05`; the main folder was not switched. Lucas lifted the open-PR cap for this run.

2. Handoff record

Field	Value
Task	Pin Pyodide, with integrity checks
Human goal	A compromised or changed CDN file can't run in a learner's browser
Non-goals	Self-hosting; Pyodide packages (no lesson loads any)
Data and compatibility	None. Learners see no change, unless the CDN serves a changed file, when Python is unavailable instead
Deployment status	Not requested

Files changed

File	Change
`frontend/public/python-worker.js`	Pinned hashes; files fetched and checked before Pyodide starts; scripts run from checked bytes; its own `fetch` copy dropped after load
`frontend/csp.mjs`	Worker policy: `script-src 'unsafe-eval'`, without the CDN
`frontend/tests/pyodide-integrity.spec.ts`	New: 11 tests
`frontend/tests/allowed-imports.spec.ts`	Expects the new worker policy
`docs/plan/browser-checks.md`	Section 13; section 12 marked built

3. Security note

What this stops: the CDN, or anyone between it and the learner, serving a different Pyodide. Before, `importScripts()` ran whatever came back from the pinned URL. Now nothing runs unless all five files match.

What it changes: the worker's policy loses the CDN from `script-src`, so no script from anywhere can load there. `'unsafe-eval'` was already allowed (Pyodide needs it for WebAssembly), and the two scripts now run through it, from checked bytes.

One risk I found in my own first draft and fixed: keeping a copy of `fetch` to check files would have left a way to the network for learner code that reaches JavaScript. The worker now drops it once Python has loaded, and a test goes round the import guard on purpose to show it's gone.

Hashes, checked twice: taken from the CDN, and equal to the files in the npm package `pyodide@0.27.7`, whose tarball matches the registry's sha512 integrity hash.

4. Decisions and why

Decision	Options considered	Reason	Who decided
Pin with checked hashes	Self-host from the npm package	No new dependency (plan rule 6), no 14 MB of files served by the app, and the same guarantee	Implementer
Check all five files before Pyodide starts	Check each when Pyodide asks for it	A changed `.wasm` made Pyodide wait for ever instead of failing (found by a test)	Implementer
Run the scripts with indirect `eval`	A `blob:` URL with `importScripts()`	`blob:` would widen the policy; `'unsafe-eval'` is already allowed	Implementer
Refuse any other CDN file during start-up	Let it through	Fail closed	Implementer

5. Bugs found and how they were fixed

Both were in my own draft, caught by the new tests before the PR:

- **A changed `pyodide.asm.wasm` left Python "starting" for ever,** because Pyodide only logs a warning when the WebAssembly fails to load. Fixed by checking every file first.
- **A changed `python_stdlib.zip` gave an unreadable error** (`[object Object]`), for the same reason.

6. How it was tested

Command	Result
`npx tsc --noEmit` and `npm run build`	OK
`CI=1 npx playwright test tests/pyodide-integrity.spec.ts`	**11 passed**
Browser checks, allowed imports, learner files, file checks, `academy`, lesson units, function checks, reference checks	**150 passed**
Backend	Not changed. Runs in CI
The full browser suite	**In CI on this PR**

The tests change the last byte of each file in turn, on its way to the worker, and check Python is then unavailable both in a check and in Try it. Another checks every pinned hash against the CDN.

Deliberate-break controls (each undone; the worker matched its saved copy byte for byte afterwards)

What I broke	Tests that failed
B1. Hashes not compared	**5**
B2. `fetch` copy kept after load	**1**
B3. Other CDN files let through	**0.** Pyodide asks for no other file at start-up, which a test checks, so this rule can't be shown failing without changing Pyodide

7. Known limitations

- **Still depends on the CDN being up.** If it is down, Python is unavailable, as before.
- **Start-up waits for all five files,** about 14 MB, before anything runs. WebAssembly is compiled from memory instead of while downloading. In my test the first run took about one second on a fast connection.
- **The "every hash matches the CDN" test needs the network,** as the other browser tests already do.

8. Live checks for you

After deploying, open a lesson, run Try it, and check DevTools → Console shows no CSP reports, and that the worker's requests in DevTools → Network are the five files.

9. Questions for you

1. **Is pinning without self-hosting enough for now?** *Recommended: yes. Revisit if the CDN is ever unreliable.*

10. For the docs sync

Where	What
Backlog	SEC-05 `in_review` (#PR, handoff 44)
Stage table	"44. Pyodide integrity | SEC-05 | in_review (#PR, handoff 44)"
Decision log	Pinned hashes chosen over self-hosting

11. Next concrete action

Review and merge.

12. Removing the worktree safely

From the **main** folder, after this PR is merged:

```
cd /Users/DEV/Projects/python-academy
git -C ../python-academy-sec05 status --short   # expect nothing
git worktree remove ../python-academy-sec05
git worktree prune
git branch -d sec/pyodide-integrity
```